

Customer Security Brief

RAG-Based Document QA System

Prepared for enterprise security review. This document summarizes architecture, data handling, security controls, auditability, and governance for the RAG platform.

1. End-to-End Data Flow

User → Prompt Guard → Query Extraction → Hybrid Retrieval (BM25 + Vector + RRF) → Cohere Rerank → Context Builder → PII Redaction → SQLite Prompt Cache → GPT-4.1 (GPT-4.1-mini fallback) → Answer + Citations + LangSmith Trace

2. Security Control Matrix

Control	Implementation	Benefit
Prompt Injection	Enterprise Prompt Guard	Blocks malicious prompts
PII Protection	Microsoft Presidio	Redacts sensitive data
Grounding	Hybrid Retrieval + Rerank	Reduces hallucinations
Observability	LangSmith	Complete audit trail
Caching	SQLite Cache	Lower latency & cost
Fallback	Model Router	Higher availability

3. Data Retention

- SQLite prompt cache uses a configurable TTL.
- Retrieved documents remain within the indexed knowledge base.
- LangSmith stores operational traces for debugging and evaluation.
- Organizations should define retention periods for prompts, traces, logs, and backups.

4. Audit Trail

Every request records retrieval metadata, reranker results, retrieved document IDs, chunk IDs, prompt version, cache hit/miss, selected model, fallback status, latency, PII detection status, prompt guard decisions, attack type, severity, and matched rule.

5. Vendor Security Checklist

- SOC 2 Type II
- ISO/IEC 27001
- ISO/IEC 27701
- GDPR / DPA support
- Encryption in transit and at rest
- Customer-managed retention
- Key rotation & secret management
- Penetration testing reports
- RBAC and audit logging

6. Threat Model

Threat	Mitigation
Prompt Injection	Prompt Guard
Prompt Leakage	Block prompt extraction attempts
Sensitive Data Exposure	PII Redaction
Hallucinations	Grounded Retrieval + Citations
Model Outage	Fallback Router
Operational Visibility	LangSmith Tracing

Executive Recommendation

The implemented RAG system demonstrates production-oriented engineering with layered retrieval, security guardrails, PII redaction, observability, evaluation, prompt caching, and model resilience. Prior to production deployment, validate vendor certifications, define retention policies, and periodically review guardrail rules and evaluation results.